

Achieving Compliance (ISO 27001 · NIS2 · SOC 2)

The business must achieve and hold compliance — but a rack of point solutions makes every control harder to configure, every edge harder to cover, and every audit a manual evidence-hunt. This use case positions Cato CASB + DLP with one management plane: risk-based SaaS control, protection of regulated data, and unified audit evidence mapped to ISO 27001, NIS2 and SOC 2.

ISO 27001

NIS2

SOC 2

CASB

DLP

BUSINESS OBJECTIVE

Why this matters

Work in progress

The source deck for this use case is marked WIP — the story arc and framework mappings are solid, but the demo runbook below is **starter guidance** authored for this library, not a field-validated script. Rehearse it in your own tenant before running it with a customer.

For most organisations compliance is not optional: it is a condition of trading. Frameworks like ISO 27001, NIS2 and SOC 2 decide whether customers will sign, whether regulators stay satisfied, and whether insurers will underwrite cyber risk.

The problem is *how* compliance is achieved. Security built from point solutions is slow to manage, leaves gaps between tools, and adds supply-chain risk with every extra vendor. Evidence lives in a dozen consoles, and every audit becomes a correlation project. The position this use case builds: **Cato CASB + DLP, enforced everywhere and reported from one management plane, gives you the controls and the evidence in one place** — a deployment plan that ends with compliance achieved, not just tooling bought.

What ISO 27001, NIS2 and SOC 2 actually are

ISO 27001

An international standard to establish, implement and maintain information security — an auditable Information Security Management System (ISMS) with certification the business can show customers.

NIS2

The EU framework for protecting critical infrastructure: ensure the security and resilience of essential services and prevent, deter and mitigate major incidents. Legally binding for in-scope entities.

SOC 2

An audit of the controls behind security, availability, confidentiality and privacy — the attestation report enterprise buyers increasingly demand before they will sign.

Six things compliance owners tell us

Slow management

"It takes us weeks to configure the same policy across all the tools."

Control sprawl

"My network security is a mess. Just too many boxes and models."

Audit evidence

"How do I correlate evidence across all this tooling?"

All edges

"How do I make sure remote workers are kept compliant?"

SaaS activity

"I need to ensure my SaaS usage is controlled."

Governance

"Shadow IT and unknown SaaS apps make it difficult to comply."

Discovery question

"Which framework is driving you right now — and when the auditor asks for evidence that a control worked last quarter, how many consoles do you have to open to answer?"

The business impact of falling short



Reputational impact

A failed audit or a public incident undermines the trust the brand trades on.



Regulatory exposure

Industry regulatory requirements don't negotiate — non-compliance invites enforcement.



Blocked growth

Without the certification or attestation, new customers can't be signed — the business can't grow at the desired pace.

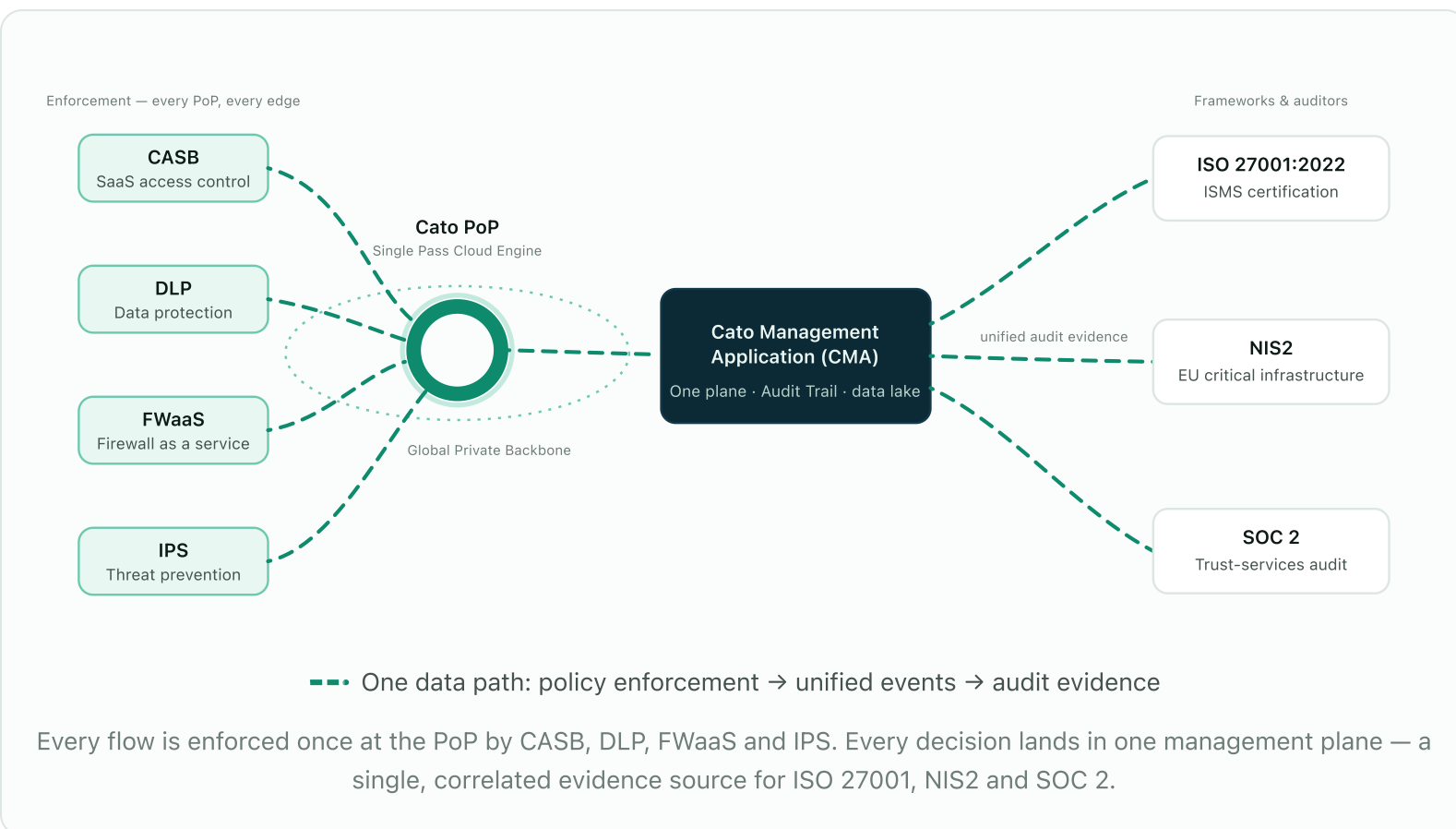


Uninsurable risk

Cyber insurers demand demonstrable controls; without them the business can't be insured against attack.

CASB + DLP, with one evidence plane

Cato converges the controls the frameworks keep asking for — cloud-service governance, access control, information classification and transfer control — into the same single-pass engine that carries the traffic. Every flow from every edge is inspected once at the PoP, and every decision lands as an event in one management application. That is the difference between *owning tools* and *producing evidence*.



How CASB + DLP move the compliance needle

Application Dashboard — shadow IT visibility

Continuous monitoring of every cloud app in use, sanctioned or not, including DLP events with forensic evidence — the governance gap made visible.

Risk-based CASB controls

Access to cloud services governed by application risk — allow the sanctioned, restrict the risky, block the unacceptable, from one rule base.

DLP for regulated data

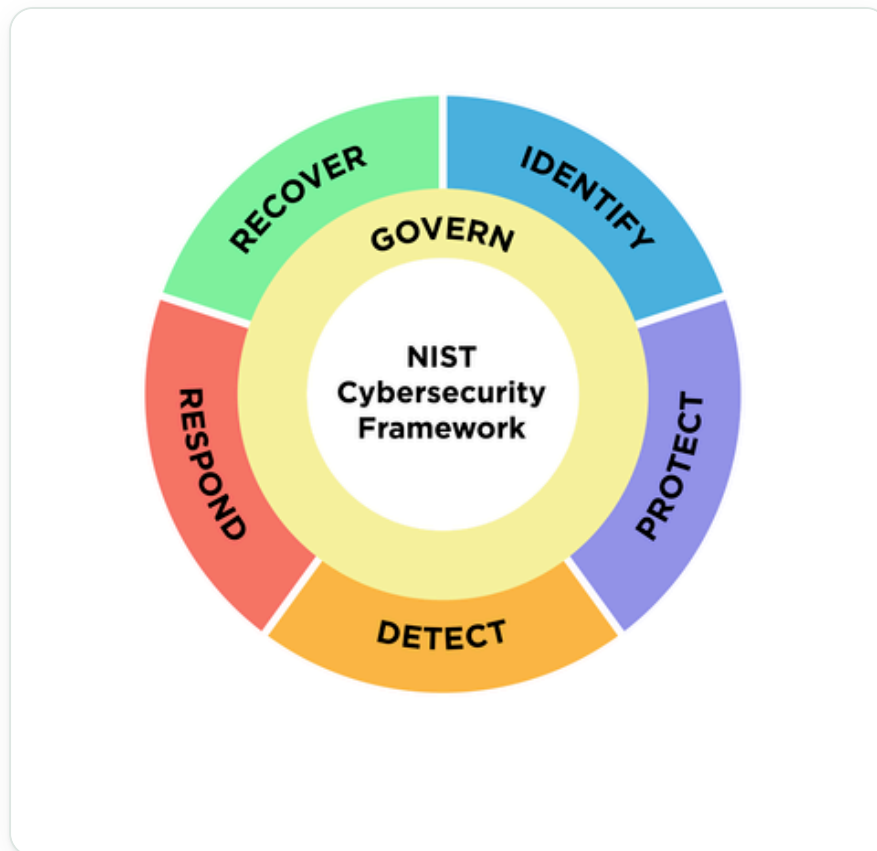
Alerting and control of regulated and sensitive data — PCI, PII, financial records — as it moves between users, SaaS and the internet.

App Catalogue — vendor due diligence

Review which applications hold which compliance attestations before the business relies on them — supplier due diligence in minutes, not weeks.

NIS2 Article 21 → NIST CSF → Cato

NIS2's Article 21 security areas align closely with the NIST Cybersecurity Framework functions — and those functions are exactly what the Cato SASE Cloud already delivers. Use the wheel to frame the conversation, then walk the mapping.



NIST CSF 2.0 — NIS2 Article 21 directives map cleanly onto these functions.

NIS2 SECURITY AREA	NIST CSF FUNCTION	CATO SASE CLOUD APPROACH	CATO TECHNOLOGY / SERVICE
Incident handling & reporting	Detect · Respond	Thresholds for alerts and events; security scores; MITRE ATT&CK dashboards; threat/incident reports; remediation	CMA · MDR · XDR
Business continuity	Identify — Business Environment	Cloud-native, fully meshed architecture; 99.999 % uptime SLA between PoPs	Global private backbone · HA everywhere · redundant Tier-1 links
Supply-chain security	Detect — Continuous Monitoring	Granular access-control policies	NGFW · CASB · DLP
Systems acquisition, development & maintenance	Identify — Risk Assessment · Protect — Data Security	Automatic security assessment against best practices; full encryption of data in transit and at rest with proprietary distributed KMS	CMA · Cato Socket · Cato Client · Cato PoPs / data lake
Cryptography & encryption	Protect — Data Security	Full encryption of data in transit and at rest with proprietary distributed KMS	Cato Socket · Cato Client · Cato PoPs / data lake
Access-control policies	Protect — Access Control	RBAC; MFA; SSO	CMA
Asset management	Identify — Asset Management	Full application awareness; full context flow awareness	DPI · NGFW · CASB · IPS
Zero-trust security	Protect — Access Control	Universal ZTNA with continuous assessment; MFA; SSO	CMA · Cato Socket · Cato Client

ISO/IEC 27001:2022 clauses 4–10 mapped to Cato

Important caveat — say this out loud

Clauses 4–10 are **customer-owned ISMS requirements**. Cato supports them with controls, telemetry and evidence — but it does not replace your governance, risk, audit or corrective-action processes. Position Cato as the engine inside the ISMS, not a substitute for it.

Clause	How Cato Maps	What Customer Still Owns	Coverage
4 — Context	Treat Cato as an externally provided cloud security/networking service inside scope, supplier and dependency analyses; Cato's security/compliance materials and DPA support supplier due diligence.	Scope boundaries, legal/regulatory requirements, interested-party expectations, supplier risk in business context.	Indirect
5 — Leadership	Very little direct product mapping — centralised administration and managed services support execution, but leadership evidence remains internal.	Approve policy, assign owners, fund the ISMS, run governance forums, demonstrate oversight.	Minimal
6 — Planning	Candidate technical treatments and evidence for the Statement of Applicability: ZTNA, NGFW, SWG, IPS, CASB, DLP, DNS Security, TLS inspection, logging, XDR and MDR.	Risk methodology, risk evaluation, control selection and exclusions, the SoA itself, measurable objectives.	Moderate
7 — Support	Unified management plane, telemetry, documentation, integrations and optional managed services that help run security operations and preserve evidence.	Training and awareness, document and record control, communications, competence records.	Partial
8 — Operation	The strongest fit: central enforcement of access control, network security, web filtering, cloud-app control, DLP, logging, monitoring and detection/response across users, sites and cloud traffic.	Operating procedures, change approval, exceptions, vendor supervision, event investigation, assurance over outsourced processes.	Strong
9 — Performance evaluation	Dashboards, event telemetry, the data lake, XDR stories and SIEM integrations supporting monitoring and control-effectiveness evidence.	KPIs, effectiveness reviews, internal audits, compliance evaluation, management reviews.	Moderate
10 — Improvement	Telemetry, threat stories and vendor-delivered service updates surface weaknesses and improvement opportunities — inputs to improvement, not the corrective-action process itself.	Root-cause analysis, nonconformity records, corrective actions and verification, continual improvement.	Partial

How to run the demo

Starter guidance

The source deck's demo slide is an empty placeholder, so this runbook was authored for the library from the capabilities the deck positions. Validate each step in your own tenant and adapt to the framework your prospect cares about.

1 Open on shadow IT — the governance gap

Monitor → Cloud Apps Dashboard

Show the full picture of cloud application usage across the tenant: how many apps are in use, sanctioned vs unsanctioned, and their risk scores. Tie it back to the quote — “shadow IT and unknown SaaS apps make it difficult to comply.” You can't govern what you can't see.

2 Vendor due diligence in the App Catalogue

Drill from the dashboard into a specific SaaS app's App Catalogue entry. Show its risk score and compliance attributes — which certifications and attestations the vendor holds. This is supplier due diligence (ISO 27001 clause 4, NIS2 supply-chain security) reduced from weeks of questionnaires to a lookup.

3 Build a DLP rule for PCI data

Security → DLP Configuration

Create (or walk through) a rule using a credit-card/PCI data profile: block uploads containing cardholder data to unsanctioned apps, with an event logged on every match. Narrate it as “information classification and transfer control” — the language auditors use.

4 Show the evidence — Data Protection Dashboard

Monitor → Data Protection Dashboard

Switch from control to proof: DLP events over time, top triggered rules, the users and apps involved. When Priya from finance trips the PCI rule, the event is right here with full context — this is the control-effectiveness evidence clause 9 asks for.

5 Change governance — Audit Trail

Administration → Audit Trail

Show every administrative change in the tenant: who changed which policy, when, from where. One attributable change record across the entire security stack — change management evidence without correlating five consoles.

6

Close on exportable reports

Export the dashboards you have just shown and explain that reporting can be generated on a recurring basis for the compliance team. The close: “when the auditor asks, this is one evidence pack from one platform — not a quarter's worth of screenshot-gathering.”

GO DEEPER

Resources

Documentation

- [Cato security, compliance & privacy](#)
- [CASB — platform page](#)
- [DLP — platform page](#)
- [Cato Management Application \(CMA\)](#)
- [Best practices for Cato event logs & ingestion \(KB\)](#)

In this library

- [Data Security with CASB & DLP](#)
- [Data Breach Investigation with DLP Forensics](#)
- [Cloud-Delivered Inbound Protection](#)